

Relatorio de auditoria e testes da aplicacao

Seguranca, funcionalidades, banco de dados, dependencias e experiencia de uso

Data da avaliacao

10 de agosto de 2026

Ambiente

Aplicacao local com PostgreSQL e acesso temporario por Cloudflare Tunnel

CLASSIFICACAO: USO INTERNO

1. Resumo executivo

A aplicacao apresentou bom funcionamento nos fluxos centrais e passou em todos os testes automatizados executados. Entretanto, foram identificados tres riscos de alta prioridade que impedem a recomendacao de uso em producao neste momento.

61	47	0	3
testes automatizados aprovados	arquivos JavaScript sem erro de sintaxe	vulnerabilidades conhecidas em dependencias	riscos de alta prioridade

ALTO	Exposicao de dados de reservas e fotos
	Usuarios autenticados recebem a colecao completa de reservas, incluindo dados operacionais e fotos em Base64. A resposta observada tinha aproximadamente 249 KB com apenas tres reservas.
ALTO	HTTPS e cookie de sessao
	O ambiente permite HTTP e utiliza SESSION_COOKIE_SECURE=false. Nao foram encontrados redirecionamento obrigatorio para HTTPS nem HSTS.
ALTO	Integridade da auditoria
	Um usuario autenticado comum conseguiu criar um evento arbitrario no historico de auditoria. A origem do evento e real, mas seu significado pode ser forjado.

Conclusao

O CapriCar esta adequado para continuidade do desenvolvimento e testes internos controlados. A liberacao para producao deve ocorrer somente depois da correcao dos tres riscos de alta prioridade e de uma nova rodada de validacao.

2. Escopo e metodologia

A avaliação combinou testes automatizados, inspeção de código, consultas de integridade no PostgreSQL, testes HTTP e validação manual da interface em desktop e celular.

Area	Procedimentos executados	Resultado
Aplicação	Fluxos de reserva, edição, cancelamento, carona, notificações, calendário e gestão	Fluxos centrais aprovados
Segurança	Autenticação, autorização, sessão, origem, entradas, cabeçalhos, dados e auditoria	Tres riscos altos identificados
Banco de dados	Contagens, duplicidades, migrações, backup e verificação do catálogo	Integridade básica aprovada
Dependências	Auditoria de pacotes de produção e verificação de versões	Nenhuma vulnerabilidade conhecida
Responsividade	Navegação em viewport de 390 x 844 e verificação de overflow	Sem overflow horizontal nos fluxos testados

Ambiente avaliado

- Servidor Node.js local em http://127.0.0.1:3000.
- Banco PostgreSQL local.
- Acesso externo temporário por Cloudflare Tunnel.
- Tema claro e escuro, interface desktop e interface móvel.
- Contas temporárias isoladas para testes de permissões; removidas ao final.

Critério de severidade

Nível	Interpretação
Alto	Pode causar exposição de dados, comprometimento de sessão ou perda de confiabilidade de registros.
Medio	Pode provocar abuso, inconsistências, indisponibilidade ou degradação importante conforme o uso cresce.
Baixo	Melhoria de defesa, privacidade operacional, manutenção ou experiência de uso.

3. Resultados dos testes

Testes automatizados

Conjunto	Quantidade	Resultado
Regras e funcoes centrais	22	Aprovado
Exportacao XLSX	1	Aprovado
Permissoes de interface	5	Aprovado
Permissoes de backend	2	Aprovado
Seguranca de backend	7	Aprovado
Validacao de dados	11	Aprovado
Exclusao de veiculo	1	Aprovado
Exclusao de filial	3	Aprovado
Notificacoes	6	Aprovado
Numeracao de reservas	3	Aprovado
Total	61	Todos aprovados

Testes manuais funcionais

Fluxo	Evidencia observada
Autenticacao	Login valido aceito; credencial invalida rejeitada; rotas protegidas retornaram 401/403.
Reserva	Reserva temporaria criada, exibida em Minhas Reservas, editada e cancelada.
Regras	Confirmacao mostrou apenas o campo modificado; cancelar restaurou o valor anterior.
Retirada	Botao indisponivel exibiu corretamente a liberacao 15 minutos antes.
Carona	Usuario comum entrou e saiu; nao recebeu opcoes de editar ou cancelar a reserva do motorista.
Notificacoes	Aviso de reserva proxima gerado e marcado como lido.
Calendario	Reserva exibida com rota, carro e solicitante.
Gestao	Todas as sete abas administrativas foram abertas e verificadas.
Celular	Nova Reserva e Calendario sem overflow horizontal em 390 x 844.

4. Achados de alta prioridade

4.1 Exposicao de reservas, operacoes e fotos

O endpoint de inicializacao carrega todas as colecoes de estado para qualquer usuario autenticado. Na verificacao com uma conta comum, a resposta incluiu as tres reservas existentes, uma foto operacional e campos como nome, motivo, passageiros e dados de retirada/devolucao.

Impacto

- Violação de privacidade entre usuarios e filiais.
- Exposicao de fotos e avarias para pessoas sem necessidade operacional.
- Persistencia dos dados recebidos no localStorage do navegador.
- Crescimento acelerado do volume transferido em cada inicializacao.

Recomendacao

Criar respostas projetadas por permissao: reservas proprias para usuarios comuns, resumo anonimo para calendario/caronas e dados completos apenas para gestao autorizada. Fotos devem ser acessadas por endpoint protegido ou URL temporaria, nunca dentro do bootstrap geral.

4.2 HTTPS e sessao

O ambiente estava configurado com cookie sem Secure, aceitou acesso por HTTP e nao enviou HSTS. Mesmo que o link divulgado utilize HTTPS, uma navegacao acidental por HTTP pode permitir o envio do cookie sem protecao de transporte.

Recomendacao

Forçar redirecionamento HTTP para HTTPS, habilitar `SESSION_COOKIE_SECURE=true`, configurar HSTS e impedir a inicializacao de producao quando a configuracao segura estiver desligada.

4.3 Auditoria controlada pelo cliente

O endpoint `/api/state/audit/event` aceita acao, entidade, identificador e descricao fornecidos pelo navegador. Uma conta comum conseguiu inserir um evento de teste arbitrario.

Recomendacao

Eliminar o endpoint generico. Cada operacao do backend deve gravar seu proprio evento de auditoria dentro da mesma transacao que altera os dados. Caso algum evento do cliente seja indispensavel, usar uma lista fechada e validacao de permissao por tipo.

5. Demais achados

Prioridade	Achado	Acao recomendada
Media	Responsavel e horario operacional podem ser informados pelo navegador.	Sobrescrever com usuario autenticado e horario do servidor.
Media	Bootstrap sensivel sem Cache-Control: no-store.	Aplicar no-store em autenticacao, estado, usuarios e notificacoes.
Media	Limitador de login em Map local e sem limite global de tamanho.	Usar armazenamento TTL limitado, com chaves por IP e conta.
Media	Estado inteiro em objetos JSON e fotos Base64.	Normalizar tabelas e armazenar fotos separadamente.
Media	Limite HTTP de 8 MB pode conflitar com varias fotos e colecao crescente.	Upload multipart direto e limites independentes por arquivo.
Media	Datas da reserva aparecem vazias no formulario de edicao.	Inicializar o seletor com o periodo atual.
Baixa	Nomes acessiveis duplicados no menu movel.	Usar um unico rotulo acessivel e aria-hidden no texto decorativo.
Baixa	Google Fonts nao permitido pela CSP atual.	Hospedar fontes localmente ou ajustar CSP explicitamente.
Baixa	Health check publico revela banco e hora do servidor.	Retornar somente {ok:true} externamente.

Aspectos positivos

- Senhas protegidas com scrypt e comparacao segura.
- Tokens de sessao aleatorios; somente o hash e armazenado.
- Cookies HttpOnly e SameSite=Lax.
- Consultas PostgreSQL parametrizadas nos pontos inspecionados.
- Origem externa rejeitada e rotas administrativas protegidas por permissao.
- CSP, X-Frame-Options DENY e X-Content-Type-Options nosniff presentes.
- Nenhuma vulnerabilidade conhecida encontrada nas dependencias de producao.

6. Banco de dados, backup e operacao

As verificacoes de integridade nao encontraram duplicidade de nomes de usuario, placas ausentes, sessoes expiradas, identificadores de reserva duplicados ou numeros de reserva repetidos. Sete migracoes estavam aplicadas no ambiente avaliado.

Verificacao	Resultado
Reservas apos limpeza	3 registros originais
Usuarios temporarios	0 remanescentes
Eventos artificiais de auditoria	0 remanescentes
Duplicidade de usuario	Nao encontrada
Duplicidade de ID/numero de reserva	Nao encontrada
Veiculos sem placa	Nao encontrados
Migracoes aplicadas	7

Backup de seguranca

Foi criado o arquivo backups/capricar-2026-08-10T18-50-17-095Z.backup, com 128.983 bytes. O catalogo foi lido com pg_restore e apresentou 106 entradas. A restauracao destrutiva nao foi executada; o comando de restauracao foi apenas validado quanto ao bloqueio de seguranca.

ATENCAO	O backup contem dados reais
	Armazene-o em local protegido, com controle de acesso e politica de retencao. Nao envie o arquivo em canais publicos ou junto com o codigo-fonte.

Ferramentas de desenvolvimento

O comando pnpm test nao encontrou o executavel node no PATH do ambiente Codex. Os mesmos testes foram executados diretamente pelo runtime Node disponibilizado e todos passaram. Recomenda-se padronizar Node e pnpm e executar os testes em integracao continua.

7. Plano recomendado de correcao

Fase	Prazo sugerido	Entregas
P0 - Antes de ampliar os testes	Imediato	Filtrar dados por usuario/permissoao; proteger fotos; tornar auditoria server-side; forcar HTTPS e cookie Secure.
P1 - Estabilizacao	Curto prazo	Cache no-store; timestamps server-side; rate limiting robusto; teste de integracao em CI; corrigir seletor de edicao.
P2 - Escala	Medio prazo	Normalizar reservas, passageiros e operacoes; storage de fotos; observabilidade, backups agendados e restauracao homologada.
P3 - Qualidade	Continuo	Acessibilidade, desempenho, testes E2E, experiencia movel e revisoes periodicas de dependencias.

Critérios mínimos para producao

- Nenhum usuario comum recebe dados ou fotos de reservas que nao deveria visualizar.
- Todo acesso externo utiliza HTTPS, HSTS e cookies Secure.
- Eventos de auditoria sao originados exclusivamente por operacoes do servidor.
- Testes de integracao e permissoao executam automaticamente em ambiente limpo.
- Backup e restauracao sao testados em banco separado, sem risco para os dados reais.
- Exportacoes e upload/download de fotos sao validados ponta a ponta.

STATUS	Recomendacao final
	Continuar o piloto somente de forma interna e controlada. Realizar uma nova auditoria focada depois das correcoes P0 antes de liberar o sistema para uso corporativo amplo.

8. Limitações e evidências técnicas

Limitações

- O teste automatizado `tests/api-integration.test.js` não foi executado porque `CAPRICAR_TEST_ADMIN_PASSWORD` não estava configurada. Os fluxos principais equivalentes foram testados manualmente.
- A geração XLSX passou no teste automatizado, mas o ambiente de automação não capturou o evento de download do navegador para CSV, Excel e PDF.
- Upload e download de fotos com arquivos reais exigem uma rodada dedicada de teste ponta a ponta.
- A varredura reduz riscos, mas não constitui garantia absoluta de ausência de vulnerabilidades.

Referências no código

Tema	Arquivo e linha
Bootstrap de estado	<code>server/routes/state.js:256-328</code>
Evento genérico de auditoria	<code>server/routes/state.js:681-693</code>
Cookie de sessão	<code>server/routes/auth.js:13-21</code>
Limitador de login	<code>server/routes/auth.js:8-35</code>
Cabeçalhos e limite HTTP	<code>server/index.js:19-46</code>
Campos operacionais	<code>server/validation.js:146-147 e 235-236</code>
Persistência local	<code>js/api.js:125-154</code>

Rastreabilidade da execução

Foram utilizadas contas temporárias com e sem permissões para validar separação de acesso. Ao final, contas, sessões, notificações, reservas e eventos artificiais foram removidos. A consulta final confirmou zero usuários de auditoria, zero eventos artificiais e a permanência das três reservas originais.